

CREATIC

Arquitectura **Zero Trust + Defensa en Profundidad**

Costo de licencias: **\$0** · 100% Open Source

Maestría en Ciencias Computacionales — UTP · Tópicos Especiales · Grupo 1M3213

El problema: lo que ya pasó

- **Spear-phishing** exitoso a docentes
- **Credenciales administrativas** expuestas en la Dark Web
- **Ransomware** en equipos remotos
- **Red plana** sin control: lentitud y sin visibilidad

El modelo de "perímetro de castillo" está **roto**. Cada incidente tiene costo financiero, **legal (Ley 81)** y reputacional.

M-Trends 2026: exploits = vector #1 (32%); hand-off de acceso en 22 s (p.3, p.5).

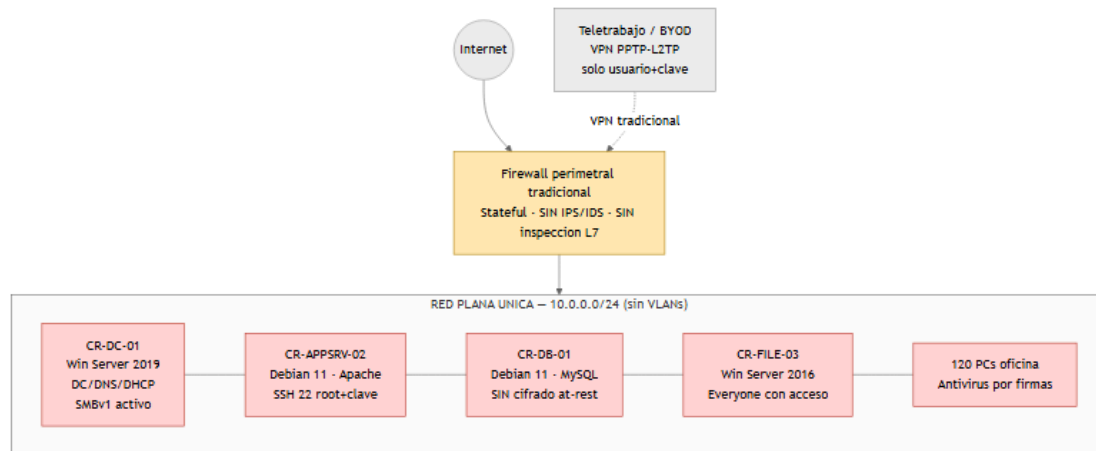
Nuestro enfoque: Zero Trust

Tres principios (NIST SP 800-207):

1. **Verificar continuamente** — nada se confía por estar en la red
2. **Mínimo privilegio** — solo el acceso estrictamente necesario
3. **Asumir la brecha** — segmentar para contener el daño

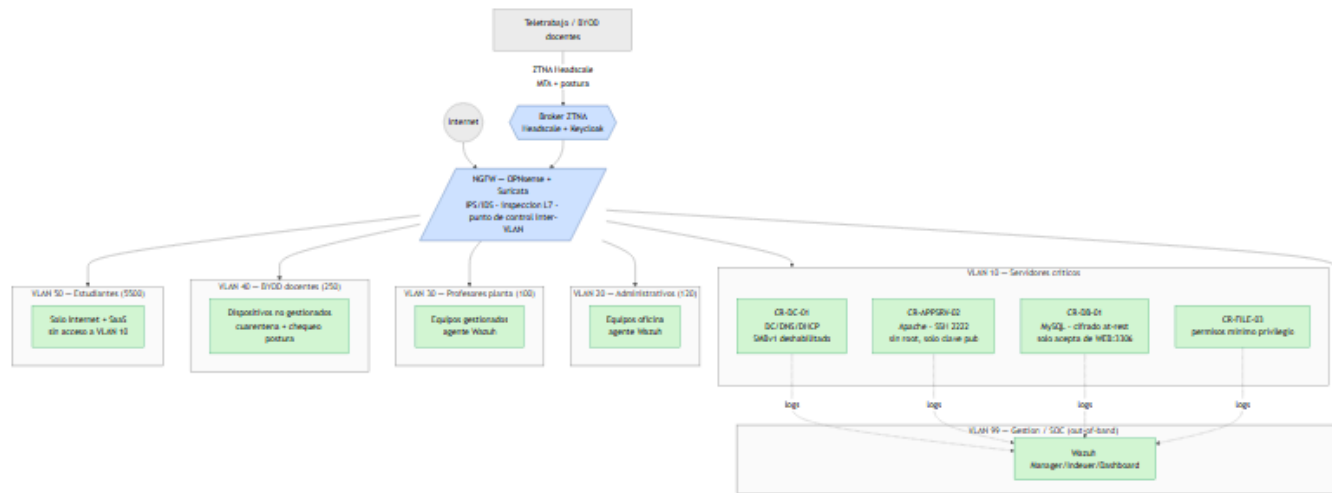
Más **Defensa en Profundidad**, todo con **Open Source** de nivel empresarial.

Antes vs Después (1/2): el problema



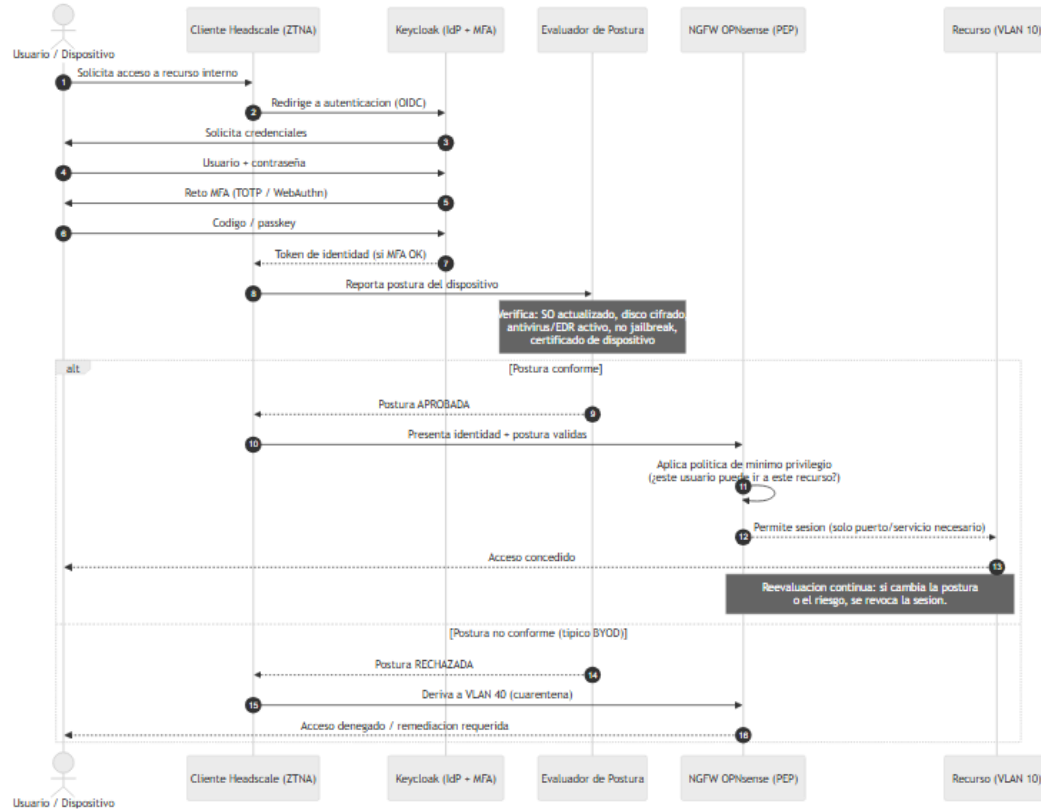
Red plana: el servidor web y la base de **finanzas** son vecinos → movimiento lateral libre.

Antes vs Después (2/2): la solución



6 VLANs + NGFW con IPS/IDS. "El web y las finanzas ya no son vecinos."

Identidad y acceso: ZTNA + MFA



VPN insegura → **Headscale (ZTNA)** + **Keycloak (MFA)** + postura del dispositivo.

"Una contraseña robada ya no basta para entrar."

Visibilidad: el SOC con Wazuh

- **Wazuh** (SIEM/EDR Open Source): Manager · Agent · Indexer · Dashboard
- Ingesta de los **4 servidores** (Syslog + Windows Event)
- **4 reglas de correlación** mapeadas a **MITRE ATT&CK**
- BYOD: cuarentena + visibilidad por NGFW

Objetivo **MTTD < 1 h**: ver el ataque mientras ocurre, no 14 días después.

Desarrollo seguro (SecDevOps)

FTP manual → **pipeline CI/CD** con compuertas:

Etapa	Herramienta	Detecta
SCA	Trivy + Dependabot	el RCE de la librería PDF
SAST	Semgrep	OWASP Top 10
DAST	OWASP ZAP	fallos en ejecución

Si el RCE llegara a pasar, la **segmentación impide que toque finanzas (CR-DB-01)**.

Hardening automatizado (código real)

- **Ansible** (Linux) + **PowerShell** (Windows)
- **Parametrizado**, comentado en español, **con verificación** post-cambio
- SMBv1 off · root-SSH off · cifrado at-rest · permisos mínimo privilegio

No son recomendaciones en papel: es **infraestructura como código**, ejecutable y auditable.

Cumplimiento legal (Ley 81 / ANTAI)

- **MFA** → deber de seguridad (Art. 31; principio Art. 2)
- **Cifrado** de datos sensibles (calificaciones, finanzas)
- **Retención de logs** en Wazuh + notificación de brechas (72 h, Decreto 285)
- Derechos **ARCO** (Art. 15, 21)

Blindaje legal: podemos **demostrar diligencia** ante una auditoría de la ANTAI.

Riesgo: antes y después

Activo	Riesgo inherente	Control	Residual
CR-DB-01 (finanzas)	20 Crítico	segmentación + cifrado + SIEM	6 Medio
CR-DC-01 (dominio)	20 Crítico	SMBv1 off + MFA + EDR	8 Medio
Red plana	20 Crítico	VLANs + NGFW IPS	6 Medio

Reducción medible del riesgo (10 riesgos, metodología NIST 800-30 / ISO 27005).

Viabilidad económica: \$0 en licencias

Necesidad	Comercial	Nuestra elección (OSS)
NGFW + IPS	Palo Alto	OPNsense + Suricata
ZTNA	Zscaler	Headscale
SIEM/EDR	Splunk / CrowdStrike	Wazuh
MFA	Okta	Keycloak

Misma capacidad, **sin costo de licenciamiento**. Sostenible para la institución.

Hoja de ruta y cierre

1. **Quick wins** (sem. 1–2): hardening + MFA
2. **Columna vertebral** (3–6): VLANs + NGFW + ZTNA
3. **Visibilidad** (5–8): Wazuh + reglas
4. **Desarrollo seguro** (6–9): CI/CD

Solicitamos la aprobación de la junta directiva.

Ante un incidente, **3 acciones exactas** (de nuestro IRP + arquitectura):

1. **Contener** → aislar VLAN en el NGFW OPNsense
2. **Cortar acceso** → revocar sesión/identidad en Keycloak (ZTNA)
3. **Detectar/erradicar** → regla Wazuh + restaurar backup limpio

"Cada acción sale de un control que ya diseñamos. Eso es Zero Trust bajo presión."